

MULTIMEDIA UNIVERSITY, MALAYSIA

Social Engineering & Penetration Testing Capstone

ETHICAL HACKING AND PENETRATION TESTING
CCS6324 - 2530

Dr. Hafiz Adnan Hussain



DISCLAIMER



- This course is designed to educate students on ethical hacking principles. The knowledge and techniques acquired must be used responsibly and not for any illegal or unauthorized activities.
- Each student is solely responsible for their actions.
- Do not investigate individuals, websites, servers or conduct any illegal activities on any system you do not have permission to analyze.
- The course content has been developed in good faith, drawing from the author's experience and reputable sources. While every effort has been made to ensure accuracy, the author does not guarantee absolute correctness. Students are encouraged to exercise discretion and actively engage in discussions by raising any questions or concerns during the course.

Learning Objectives



What You Will Learn?

- Understanding of human psychology in Social Engineering (SE)
- Recognize AI-driven SE threats
- Follow structured pentest methodology
- Identify physical security gaps
- Ensure legal/ethical testing is conducted
- Improve resilience (awareness + IR)
- Grow via certifications/specialization

1: Advanced Social Engineering in 2025



1.1 Evolution of Social Engineering

Social engineering (SE) has transformed from simple phone pretexting to sophisticated, multi-vector attacks leveraging artificial intelligence and behavioral psychology. Understanding this evolution is critical for ethical hackers and security professionals.

Historical Context → Modern Reality:

- 1980s-1990s: Basic phone pretexting, physical infiltration
- 2000s: Email phishing emerges as a dominant vector
- 2010s: Spear phishing, targeted attacks on high-value individuals
- 2020s: AI-enhanced, personalized, real-time social engineering
- 2025: Autonomous SE bots, behavioral prediction, deepfake integration

Current Statistics: **98%** of cyberattacks involve a social engineering component (Sprinto, 2024). It makes human-centered attacks the most prevalent security threat globally.

1: Advanced Social Engineering in 2025 (Cont'd)



1.2 Psychological Principles Driving Social Engineering

Successful social engineering exploits predictable human cognitive biases. Security professionals must understand these to both defend against and ethically test organizational resilience.

Core Psychological Principles:

Authority & Trust: Attackers impersonate trusted figures (IT support, executives, law enforcement). Humans naturally defer to perceived authority, making this highly effective.

Reciprocity: If someone provides a favor or gift, targets feel obligated to return it. An attacker offering assistance creates psychological debt.

Scarcity & Urgency: Limited-time offers or emergency scenarios bypass rational thinking. "Your account will be locked in 24 hours" triggers panic responses.

Social Proof: People validate actions by observing others. Phishing emails claiming "thousands have verified their accounts" leverage this principle.

Liking & Familiarity: People comply more readily with those they like or recognize. Attackers build rapport through commonalities or by developing a persona.

Commitment & Consistency: Once someone commits to a position, they defend it. Gradual requests build on previous agreements.

1: Advanced Social Engineering in 2025 (Cont'd)



1.3 AI-Powered Social Engineering Attacks

AI is fundamentally changing the social engineering landscape, enabling attacks at scale with unprecedented personalization.

AI Applications in SE:

Behavioral Analysis: Machine learning models analyze social media, news, and public records to build detailed victim profiles. Attackers know job titles, interests, recent company changes, and interpersonal relationships before contact.

Content Generation: Natural language generation (NLG) creates contextually appropriate phishing emails tailored to individual targets. Generic phishing is declining; personalized AI-generated content is rising.

Voice & Video Synthesis: AI voice cloning and deepfake generation enable convincing impersonation in real-time video calls or audio messages. A CFO can be impersonated with 30 seconds of prior audio samples.

Timing Optimization: Predictive models determine when targets are most susceptible (end of workday, Monday mornings, post-vacation stress).

Multi-Channel Coordination: AI orchestrates coordinated attacks across email, SMS, social media, and phone calls simultaneously, overwhelming traditional defenses.

Case Study: In 2024, an AI-generated deepfake call impersonating a CEO convinced a company to wire \$243,000 to a fraudulent account. The victim reported the voice and speech patterns were indistinguishable from the actual executive.

1: Advanced Social Engineering in 2025 (Cont'd)



1.4 Modern Attack Vectors Beyond Email

While email remains prevalent, sophisticated attackers diversify across multiple channels.

SMS Phishing (Smishing):

- Shorter message = higher read rates (98% vs. email's 20%)
- Context: "Your package cannot be delivered, confirm address: [link]"
- SMS bypasses traditional email filtering
- 2024 statistics: Smishing campaigns average 25% click rates

Voice Phishing (Vishing):

- Interactive dialogue allows real-time manipulation
- Attacker adjusts tactics based on victim responses
- Impersonation of IT, HR, and external vendors
- Caller ID spoofing makes verification difficult
- Average success rate: 15% of calls yield credentials

Social Media Exploitation:

- LinkedIn connection requests from fake profiles within the target organization
- Gradual trust building before credential requests
- Exploitation of public information to craft believable pretexts
- DMs with malicious links disguised as internal resources

USB Drop/Baiting Attacks:

- Physical devices left in parking lots or common areas
- Pre-loaded with malware or credential harvesters
- Social engineering: "USB with compensation info found—open at own risk"
- Success rates remain surprisingly high (40-60% in security testing)

2: Penetration Testing Framework & Methodology



2.1 Comprehensive Penetration Test Phases

A professional penetration test follows a structured, repeatable methodology. This ensures thoroughness, legal compliance, and actionable results.

Phase 1: Scoping & Rules of Engagement (ROE)

Phase 2: Reconnaissance & Footprinting

Phase 3: Vulnerability Assessment

Phase 4: Exploitation

Phase 5: Post-Exploitation & Reporting

2: Penetration Testing Framework & Methodology (Cont'd)

2.2 Social Engineering Within Penetration Testing

Social engineering tests validate human security awareness and organizational resilience to non-technical attacks.

Phishing Campaign Testing:

Design realistic phishing emails targeting company staff.

- Research Phase: Analyze company communications, identify key employees, and understand organizational processes
- Email Design: Craft messages using principles of authority, urgency, and personalization
- Tracking: Monitor email open rates, link clicks, and form submissions
- Reporting: Calculate the percentage of employees who fell for the attack; identify departments with higher susceptibility
- Follow-up Training: Target awareness training to vulnerable populations

Credentials Harvesting:

Create mock login pages to capture employee credentials.

- Target company-specific systems: Email login, VPN portal, file sharing services
- A/B test different urgency levels and messaging approaches
- Track which messages yield the highest credential capture rates
- Demonstrate how stolen credentials enable network access

Pretext Calls & Physical Testing:

Test vulnerability to in-person and phone-based social engineering.

- Call the company's helpdesk, attempting to reset passwords without proper identity verification
- Conduct physical tailgating tests to access restricted areas
- Interview staff members (with proper authorization) about security awareness
- Document which access points are vulnerable to social engineering

2: Penetration Testing Framework & Methodology (Cont'd)

2.3 Professional Report Writing Standards

Security reports must balance technical accuracy with clear communication for non-technical stakeholders.

Report Structure:

1- Executive Summary (1-2 pages)

- Business context and testing scope
- High-level risk assessment
- Critical findings summary (Critical, High, Medium)
- Estimated remediation effort and cost impact

2- Detailed Findings (Primary section)

- Organized by severity and risk category
- For each finding: Description, evidence, impact, remediation steps
- CVSS v3.1 scoring for technical vulnerabilities
- Real-world attack scenarios explaining exploit chains

3- Remediation Roadmap

- Phase 1 (0-30 days): Critical findings; immediate action required
- Phase 2 (30-90 days): High-priority findings
- Phase 3 (90-180 days): Medium-priority findings
- Ongoing: Process improvements and awareness training

4- Appendices

- Detailed technical analysis
- Tool output and logs
- Proof-of-concept code (sanitized)
- CVSS scoring methodology

Key Writing Principles:

- Use clear, jargon-free language for executive sections
- Avoid blame language; focus on risk and remediation
- Include visual aids: charts, graphs, timeline diagrams
- Provide actionable recommendations with resource estimates
- Define success metrics for remediation activities

3: Physical Security & Ethical Considerations



3.1 Physical Security Testing Methodologies

Physical security vulnerabilities are often overlooked but enable rapid organizational compromise.

Tailgating & Piggybacking Tests:

Assess whether physical access controls prevent unauthorized entry.

- Observe access control procedures at secured entry points
- Attempt to follow the authorized personnel through the doors
- Test social engineering: "Hi, my badge isn't working—could you hold the door?"
- Assess security guards' awareness and response procedures
- Document which areas allow easy unauthorized access

Badge & Credential Analysis:

Evaluate physical credential security.

- Examine visibility of ID badges (can be easily read from a distance?)
- Test whether temporary badges are tracked and revoked
- Assess whether lost badge procedures are properly implemented
- Attempt to clone or forge credentials

Dumpster Diving & Information Disclosure:

Legitimate vulnerability discovery through waste analysis.

- Examine discarded documents in trash receptacles
- Assess whether sensitive materials are shredded
- Note what information is exposed: employee names, projects, infrastructure details
- Document any credentials or configuration information found
- Assess security awareness regarding proper document disposal

Environmental Security:

Evaluate physical controls protecting sensitive areas.

- Assess surveillance camera coverage and blind spots
- Evaluate access to server rooms, data centers, and executive offices
- Identify unlocked sensitive areas or rooms with propped-open doors
- Test whether badge readers are properly maintained (avoiding worn keypads that reveal access codes)

3: Physical Security & Ethical Considerations (Cont'd)



3.2 Ethical Boundaries in Social Engineering Tests

Ethical penetration testing requires careful consideration of legal, professional, and moral boundaries.

Legal Framework:

- Written Authorization: The testing contract must explicitly authorize social engineering activities
- Scope Limitations: Define which individuals and departments are targets
- Prohibited Actions: Never commit actual crimes (fraud, theft, wiretapping)
- Data Protection: Immediately delete harvested credentials; don't use them for unauthorized access
- Regulatory Compliance: Ensure testing aligns with industry regulations (HIPAA, PCI-DSS, GDPR)

Professional Ethics:

- Psychological Impact: Social engineering tests can damage employee morale and trust. Carefully consider the organization's capacity to handle this type of testing.
- Informed Consent: While testing should maintain realism, leadership should authorize activities and plan appropriate follow-up training
- Proportional Testing: Test commensurate with organizational risk; don't conduct excessive or redundant tests
- Debriefing & Support: Provide immediate feedback and educational support to employees who fail tests

Red Team vs. Authorized Testing:

- Red Team Operations (Full-scope): Comprehensive, aggressive testing mimicking real attackers. Requires the highest-level authorization.
- Authorized Penetration Tests (Defined scope): Structured testing with clear rules of engagement and targeted testing parameters.

Neither justifies actual damage, illegal activity, or psychological harm to unwitting employees.

3: Physical Security & Ethical Considerations (Cont'd)



3.3 Career Paths & Industry Certifications

Penetration testing and ethical hacking offer diverse career opportunities with recognized certifications.

Entry-Level Certifications:

- CompTIA Security+: Foundational security knowledge; prerequisite for many government positions
- CEH (Certified Ethical Hacker): Industry-recognized credential requiring ethical hacking knowledge and practical experience
- CompTIA CySA+: Security analyst focus; emphasis on vulnerability management

Mid-Level Certifications:

- OSCP (Offensive Security Certified Professional): Hands-on penetration testing certification requiring successful completion of a challenging lab environment. Highly respected in the industry.
- GPEN (GIAC Penetration Tester): Comprehensive pentesting credential with emphasis on real-world methodology

Advanced Certifications:

- GWAPT (GIAC Web Application Penetration Tester): Specialized focus on web application security
- GCIH (GIAC Certified Incident Handler): Incident response and digital forensics focus

Career Trajectories:

- Penetration Tester: \$100K-\$150K+; requires strong technical skills and certifications
- Security Architect: \$130K-\$180K+; design secure systems; requires pentesting background
- Red Team Operator: \$120K-\$160K+; government/defense contractors; highest clearance requirements
- Security Consultant: \$90K-\$160K+; depends on specialization and experience
- Incident Response Specialist: \$100K-\$140K+; responds to security breaches; requires forensic skills

Professional Development:

- Maintain current certifications through continuing education
- Develop specializations: cloud security, industrial control systems, web applications
- Contribute to open-source security tools
- Present at security conferences; participate in capture-the-flag competitions
- Build portfolio of professional pentesting reports

4: Defensive Strategies & Organizational Resilience



4.1 Security Awareness Programs

Technical defenses fail without an informed, security-conscious workforce.

Effective Training Components:

- Baseline Assessment: Identify organizational vulnerabilities to social engineering through phishing simulations
- Targeted Training: Focus on vulnerability categories (phishing, pretexting, physical security)
- Ongoing Campaigns: Monthly or quarterly reinforcement; avoid one-time training
- Accountability: Track completion rates; make training performance part of performance reviews
- Real-World Scenarios: Use actual phishing emails and attack patterns relevant to your industry
- Leadership Engagement: Executives must participate in training to model security behaviors

Measuring Effectiveness:

- Track click-through rates on phishing simulations over time (target: <5%)
- Monitor password change frequency and complexity
- Assess incident reporting rates (employees should report suspicious activity)
- Conduct post-incident analysis: what enabled the breach?

4: Defensive Strategies & Organizational Resilience



4.2 Multi-Factor Authentication & Access Controls

Technical controls significantly reduce damage from compromised credentials.

Multi-Factor Authentication (MFA):

- Knowledge Factor: Something you know (password)
- Possession Factor: Something you have (hardware token, phone)
- Inherence Factor: Something you are (biometrics)

MFA should be mandatory for all critical systems:

- Email and VPN access
- Administrative functions
- Financial systems
- Sensitive data repositories

Privilege Access Management (PAM):

- Limit administrative privileges; users should operate with the minimum necessary permissions
- Separate personal accounts from administrative accounts
- Implement session recording for privileged access
- Require approval workflows for elevated privilege requests
- Monitor for unusual administrative activity

4: Defensive Strategies & Organizational Resilience



4.3 Detecting Social Engineering in Progress

Organizations should implement monitoring to identify and respond to ongoing attacks.

Email Security Controls:

- Advanced threat protection: URL rewriting, dynamic analysis of suspicious attachments
- DMARC/SPF/DKIM authentication: Prevent email spoofing
- User reporting mechanisms: Easy buttons to report phishing attempts
- Quarantine suspicious emails: Review before delivery

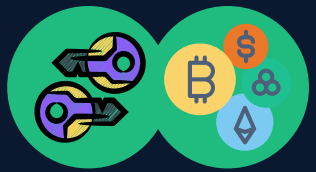
User Behavior Analytics (UBA):

- Monitor for unusual login patterns: Off-hours access, geographic anomalies
- Detect credential misuse: Wrong user accessing sensitive data
- Alert on data exfiltration attempts
- Identify potential insider threats

Incident Response Planning:

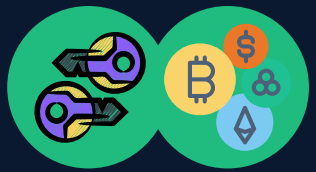
- Establish clear escalation procedures
- Define roles and responsibilities during incidents
- Conduct regular incident response drills
- Maintain playbooks for common attack scenarios
- Ensure rapid communication with affected parties

Key Takeaways For Pentesters



- Social engineering exploits predictable human psychology; understanding these principles is critical for both attackers and defenders.
- AI is transforming social engineering into more personalized, scalable, and sophisticated attacks.
- Penetration testing requires a structured methodology, clear authorization, and professional documentation.
- Physical security testing reveals vulnerabilities often overlooked by IT-focused security programs.
- Ethical boundaries, legal authorization, professional conduct, and employee welfare are non-negotiable in authorized security testing.
- Organizational resilience depends on security awareness, technical controls, and incident response capabilities.
- Certification and specialization can advance careers in a growing security industry.

References & Further Reading



- NIST Cybersecurity Framework (CSF)
- OWASP Testing Guide v4.1
- PTES (Penetration Testing Execution Standard)
- CompTIA Security+ SY0-601 Study Materials
- Offensive Security: Certified Ethical Hacker (CEH) Course Materials
- "The Social Engineer's Playbook" (Security Awareness Training Literature)
- Sprinto Cybersecurity Report 2024

Thank You

ANY QUESTIONS?

